

Relatório de Segurança da Plataforma

Avaliação de segurança em duas etapas — varredura interna (código e dependências) e varredura externa de intrusão (OWASP ZAP) contra o ambiente de produção — com as correções já aplicadas.

✓ 0 vulnerabilidades críticas ou altas em aberto

✓ Varredura externa: nenhum achado grave

**Período da
avaliação**

14 a 16 de
agosto de
2026

Escopo

Aplicação web, API,
dependências e superfície
externa

Versão

2.0 —
16/08/2026

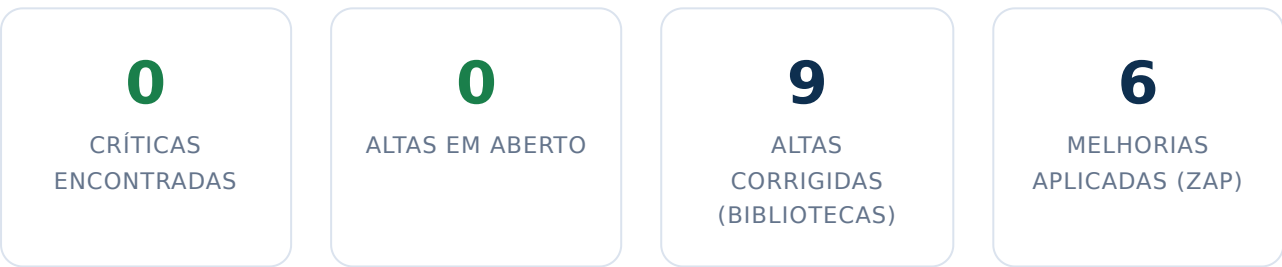
Classificação

Confidencial

1. Resumo executivo

Entre 14 e 16 de agosto de 2026, a plataforma Beeldings passou por uma avaliação de segurança em **duas etapas complementares**: (1) varreduras internas automatizadas sobre o código-fonte, as bibliotecas de terceiros e o fluxo de dados sensíveis; e (2) uma **varredura externa de intrusão com a ferramenta OWASP ZAP** — padrão de mercado utilizado por empresas de teste de invasão — executada de fora para dentro contra o ambiente de produção (www.beeldings.com.br), simulando o ponto de vista de um atacante na internet.

Resultado consolidado: **nenhuma vulnerabilidade crítica ou alta foi encontrada em nenhuma das etapas**. As 9 vulnerabilidades altas identificadas em bibliotecas de terceiros na etapa interna foram corrigidas no mesmo dia (14/08), e os apontamentos de baixo risco da varredura externa — relacionados a cabeçalhos de proteção do navegador — foram corrigidos em 16/08.



2. Metodologia

Etapa	O que verifica	Resultado
Análise de dependências (SCA) interna — 14/08	Vulnerabilidades conhecidas (CVEs) em todas as bibliotecas de terceiros utilizadas pela plataforma.	9 altas corrigidas · 0 em aberto
Análise estática de código (SAST) interna — 14/08	Padrões inseguros no código-fonte: injeções, exposição de credenciais, uso incorreto de criptografia.	Sem achados relevantes

Fluxo de dados sensíveis
interna — 14/08

Vazamento de dados pessoais ou sensíveis para logs, arquivos ou serviços externos.

Sem achados relevantes

Varredura externa de intrusão (OWASP ZAP 2.17)
externa — 16/08

Ataque automatizado de fora para dentro contra o ambiente de produção: spider tradicional e moderno (browser), análise ativa e passiva de todas as respostas.

0 graves · apontamentos de baixo risco corrigidos

Sobre o OWASP ZAP: é a ferramenta de código aberto mais utilizada no mundo para testes de segurança de aplicações web, mantida pela comunidade OWASP e adotada como base por empresas especializadas em testes de invasão. A varredura foi executada contra o endereço público de produção, sem nenhum acesso privilegiado — exatamente como um atacante externo enxergaria o sistema.

3. Etapa interna — vulnerabilidades corrigidas (14/08)

As nove vulnerabilidades abaixo estavam em bibliotecas de terceiros (não no código da plataforma) e foram **corrigidas em 14/08/2026** por atualização para as versões oficiais seguras, com varredura de confirmação registrando zero pendências:

Componente	Vulnerabilidade (CVE)	Severidade	Situação
Next.js (framework web)	CVE-2026-64649 — Server-Side Request Forgery em Server Actions	Alta	Corrigida
Next.js (framework web)	CVE-2026-64645 — Server-Side Request Forgery via rewrites	Alta	Corrigida
Next.js (framework web)	CVE-2026-64642 — Bypass de middleware/proxy no App Router	Alta	Corrigida
Next.js (framework web)	CVE-2026-64641 — Negação de serviço em Server Actions	Alta	Corrigida
nanoid (geração de IDs)	CVE-2026-67213 — Laço infinito com tamanho zero	Alta	Corrigida
nanoid (geração de IDs)	CVE-2026-67214 — Laço infinito com tamanho negativo	Alta	Corrigida
brace-expansion (utilitário)	CVE-2026-14257 — Negação de serviço por expansão ilimitada	Alta	Corrigida
brace-expansion (utilitário)	CVE-2026-13149 — Negação de serviço por expansão exponencial	Alta	Corrigida
brace-expansion (utilitário)	CVE-2026-69152 — Bypass da mitigação do CVE-2026-14257	Alta	Corrigida

4. Etapa externa — varredura OWASP ZAP e correções (16/08)

A varredura externa **não encontrou nenhuma vulnerabilidade de severidade alta ou crítica**. Os apontamentos foram de baixo risco/informativos — recomendações de "endurecimento" (hardening) de cabeçalhos HTTP, presentes em praticamente qualquer aplicação web. As correções abaixo foram aplicadas:

Apontamento do ZAP	Correção aplicada	Risco	Situação
Server Leaks Information ("X-Powered-By")	O servidor não anuncia mais a tecnologia utilizada, dificultando o	Baixo	Corrigida

	reconhecimento por atacantes.		
Missing Anti-clickjacking Header	Cabeçalhos X-Frame-Options e frame-ancestors: nenhum site de terceiros pode embutir a plataforma em um iframe (previne roubo de cliques).	Baixo	Corrigida
X-Content-Type-Options Header Missing	Cabeçalho "nosniff": o navegador não tenta "adivinhar" o tipo de arquivos, mitigando execução indevida de conteúdo.	Baixo	Corrigida
Referrer-Policy ausente	URLs internas completas não são mais repassadas a sites externos ao seguir links.	Info	Corrigida
Permissions-Policy ausente	Câmera, microfone e localização do navegador explicitamente bloqueados (a plataforma não os utiliza).	Info	Corrigida
Cookies sem flags (HttpOnly / Secure / SameSite)	Verificado: o cookie de sessão (autenticação) já possui todas as proteções — HttpOnly, Secure e SameSite. Os cookies apontados são auxiliares, sem dados sensíveis.	Baixo	Verificada

Os demais apontamentos do ZAP são informativos (ex.: "Modern Web Application", "Session Management Response Identified") ou referem-se à Content Security Policy completa, tratada na seção 6 como evolução planejada. As correções acima integram a publicação de produção subsequente à data deste relatório.

5. Controles de segurança implementados

5.1 Autenticação e sessões

- Senhas armazenadas apenas com **hash criptográfico** — nunca em texto claro.
- Sessão em **cookie HttpOnly + Secure + SameSite**: o token de acesso não é legível por scripts no navegador, mitigando roubo de sessão via XSS.
- **Proteção anti-robô (Cloudflare Turnstile)** na tela de login do ambiente de produção.
- **Limite de tentativas** (rate limiting) contra ataques de força bruta, com identificação correta do IP de origem.

5.2 Isolamento entre clientes (multi-tenant)

- Todos os dados são **segregados por cliente**: cada organização acessa exclusivamente seus próprios sites, equipamentos, alarmes e relatórios.
- O escopo do cliente é resolvido de forma centralizada no servidor a cada requisição — nunca confiado ao navegador.
- Contas de clientes inativados são bloqueadas imediatamente, inclusive nas conexões em tempo real já abertas.

5.3 Proteção de operações críticas

- Exclusões de dados críticos exigem **reconfirmação de senha**, com autorização de curta validade (5 minutos) e uso único.
- Comandos de escrita em equipamentos passam por validação de permissão e são bloqueados em pontos sem comunicação.
- **Trilha de auditoria**: ações relevantes (login, comandos, alterações) são registradas com autor, data/hora e resultado — incluindo tentativas de login que falharam.

5.4 Proteção de dados e comunicação

- Todo o tráfego externo ocorre exclusivamente sobre **HTTPS (TLS)**, com **HSTS** ativo (o navegador recusa conexões não criptografadas).
- Credenciais de câmeras e equipamentos são armazenadas **criptografadas (AES-GCM)** e só decifradas no momento do uso.
- Comunicação com gateways de campo via **MQTT autenticado**, com credenciais individuais por dispositivo e listas de controle de acesso (ACL) restritas por tópico.
- Segredos e chaves de API ficam em **cofre de variáveis de ambiente** — fora do código-fonte e do controle de versão.

- Cabeçalhos de segurança HTTP no servidor de aplicação (Helmet) e no frontend, com política de origens (CORS) centralizada e restritiva.

6. Recomendações e evolução contínua

A segurança é tratada como processo contínuo na plataforma. As frentes de aprimoramento já mapeadas incluem:

- **Content Security Policy (CSP) completa**, restringindo as fontes de scripts e estilos — ajuste fino planejado para não interferir no funcionamento da aplicação.
- **Testes automatizados de isolamento entre clientes**, garantindo de forma permanente que nenhum cadastro exiba dados de outra organização (já planejado no roadmap).
- **Varreduras periódicas** — internas (dependências e código) a cada ciclo de publicação e externas (ZAP) em marcos relevantes, mantendo o resultado de zero vulnerabilidades críticas/altas.
- Abertura a **testes de intrusão (pentest) manuais independentes** contratados pelo cliente, com apoio técnico da equipe Beeldings.

7. Escopo e limitações

Este relatório documenta os **controles de segurança implementados** e os resultados de **varreduras automatizadas internas** (análise de dependências, análise estática de código e rastreamento de fluxo de dados, em 14/08/2026) e de uma **varredura externa de intrusão com OWASP ZAP** contra o ambiente de produção (16/08/2026). Varreduras automatizadas — mesmo externas — não substituem integralmente um teste de invasão manual conduzido por especialistas; a plataforma está preparada para receber esse tipo de avaliação quando o cliente desejar.

8. Conclusão

Na data desta avaliação, a plataforma Beeldings encontra-se **sem vulnerabilidades críticas ou altas conhecidas em aberto** — resultado confirmado tanto pela análise interna quanto pela varredura externa de intrusão contra o ambiente de produção. Os controles essenciais — autenticação robusta, isolamento total entre clientes, criptografia de credenciais, trilha de auditoria, proteção de operações críticas e cabeçalhos de proteção do navegador — estão implementados. A equipe mantém rotina de atualização de dependências e correção imediata de apontamentos, como demonstrado nas duas rodadas deste relatório: **todas as correções foram aplicadas em até 24 horas após a identificação**.

